

บทที่ 5

การโจมตีเพื่อปิดให้บริการ

Denial of Services Attack

Denial of Services เป็นการโจมตีเป้าหมายด้วยวิธีการต่างๆเพื่อมิให้เป้าหมายสามารถให้บริการได้ตามปกติ ซึ่งส่วนใหญ่จะอาศัยข้อบกพร่องของโปรโตคอลประกอบกับข้อบกพร่องของระบบปฏิบัติการที่ทำงานอยู่บนเป้าหมาย ทำให้การทำงานและการตอบสนองต่อการ DoS นั้นส่งผลกระทบอย่างรุนแรงต่อสมรรถนะการทำงาน

Anomalous Packet

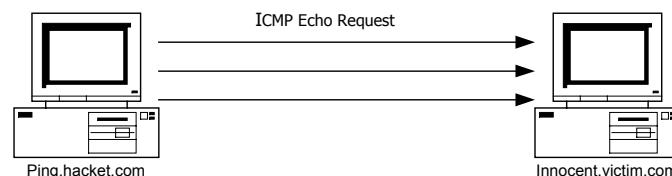
อะนอมอลัสแพ็กเก็ต(Anomalous Packet) หมายถึงแพ็กเก็ตประหลาดที่ไม่มีโอกาสเกิดขึ้นในสภาวะปกติได้โดยอย่างสิ้นเชิง แพ็กเก็ตประเภทนี้เป็นการจงใจเปลี่ยนข้อมูลสำคัญที่ใช้ควบคุมการสื่อสารข้อมูลให้ผิดปกติ ผิดธรรมชาติของการสื่อสารข้อมูลธรรมดา

ไม่ว่า IP, UDP หรือ TCP ต่างก็มีข้อกำหนดอยู่ในโปรโตคอลของตนเอง ในแต่ละโปรโตคอลย่อมมีค่าในเฮดเดอร์ที่จะใช้เพื่อกำหนดการควบคุมการสื่อสารข้อมูล โดยในสภาวะของการสื่อสารข้อมูลตามปกติแล้วค่าในเฮดเดอร์เหล่านี้จะมีค่าที่มีขอบเขตและคาดหมายได้ แต่อะนอมอลัสแพ็กเก็ตเหล่านี้จะเป็นแพ็กเก็ต ที่ถูกดัดแปลงด้วยเทคนิคของการควบคุมเน็ตเวิร์กเลเยอร์โดยตรงแบบไม่ผ่านโปรโตคอล ซึ่งเป็นช่องทางให้แฮกเกอร์ทั้งหลายได้ใช้โจมตีเป้าหมายให้ทำงานผิดพลาดไปเพราะต้องจัดการกับแพ็กเก็ตที่ไม่ได้ระบุอยู่ในโปรโตคอล หรือมีเช่นนั้นก็ใช้เพื่ออำพรางตนเองในการสำรวจเป้าหมาย เป็นต้น สำหรับการดัดแปลงของแต่ละโปรโตคอลสามารถแสดงได้พอสังเขปดังนี้

- IP : IP Length, Fragment Offset, Fragment Flag, TCP Option
- UDP : UDP Length, Socket (Address & Port)
- TCP : TCP Flag, Socket (Address & Port)

อะนอมอลัสแพ็กเก็ตที่นิยมนำมาใช้งานกันมากที่สุดเห็นจะเป็น TCP โดยเฉพาะการปรับเปลี่ยนแฟล็กไปต่างจากรูปร่างมาตรฐานที่หาได้เพื่อที่จะสามารถเปลี่ยนได้

5.1 Ping Flood Attack



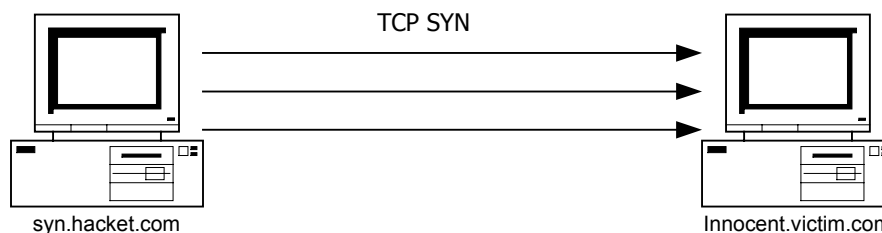
รูปที่ 5-1 แสดงการโจมตีแบบ Ping Flood Attack

Ping Flood เป็นการโจมตีที่ใช้กันในยุคแรกของ DoS เป็นการโจมตีที่มีใช้อาศัยเทคนิคกลักลับซ้ำซ้อนแต่อย่างใด อาศัยปริมาณแพ็กเก็ตมากๆเพียงอย่างเดียว แต่ถึงกระนั้นก็ตามจากการโจมตีวิธีนี้ก็สร้างความเสียหายได้ไม่น้อย

หลักการโจมตีของ Ping Flood คือการส่ง ICMP Echo Request (แบบเดียวกับที่ได้จากคำสั่ง Ping) ปริมาณมากๆ ไปยังเป้าหมายอย่างรวดเร็ว ทำให้โฮสต์ที่ถูกโจมตีจะต้องคอยตอบ ICMP Echo Reply ตลอดเวลาจนแทบจะไม่มีเวลาทำงานอื่น ความรุนแรงของการโจมตีจะมากหรือน้อยแปรผันตามความเร็วของการส่ง ICMP แพ็กเก็ตเป็นหลัก

นอกจากการสร้างเสียหายแก่เครื่องคอมพิวเตอร์เป้าหมายแล้ว Ping Flood ยังสร้างความเสียหายให้แก่เน็ตเวิร์กที่เครื่องคอมพิวเตอร์เป้าหมายนั้นอยู่ด้วย โดยความเสียหายจะมีขอบเขตน้อยเพียงใดขึ้นอยู่กับลักษณะการออกแบบของเน็ตเวิร์กนั้นๆ ถึงแม้ว่าแพ็กเก็ตที่ส่งไปยังเซิร์ฟเวอร์เป้าหมายนั้นจะมีหมายเลข IP เป็นของเป้าหมายเครื่องเดียว แต่ในความเป็นจริงที่เลเซอร์ต่ำลงไป เช่น Ethernet ต่างก็ใช้งานร่วมกันกับเครื่องโฮสต์อื่นๆในเน็ตเวิร์ก การที่ข้อมูลจะเดินทางจากที่ใดและจะไปที่ไหนจะต้องผ่านเน็ตเวิร์กที่ใช้งานร่วมกันนี้ ดังนั้นเมื่อแพ็กเก็ตจำนวนมากถูกส่งมายังเครื่องเป้าหมาย นอกจากจะทำให้เครื่องเป้าหมายเสียหาย แล้วเน็ตเวิร์กอันเป็นทางผ่านก็จะเต็มไปด้วยแพ็กเก็ตนี้เช่นกัน ลักษณะเช่นนี้จะเกิดมากบนเน็ตเวิร์กที่มีการใช้การสื่อสารเลเซอร์ต่ำร่วมกันเช่น 10Base-5 หรือ 10Base-T ที่ใช้ Hub เป็นตัวกระจายสัญญาณ

5.2 SYN Flood Attack



CERT Advisories : CA-1996-21 TCP SYN Flooding and IP Spoofing Attacks
 CVE - 1999-0116
 Description : Denial of service when an attacker sends many SYN packets to create multiple connections without ever sending an ACK to complete the connection, aka SYN flood

รูปที่ 5-2 แสดงการโจมตีแบบ SYN Flood Attack

ถ้าจะนับว่าการโจมตีของ Ping Flood เป็นการทดลองกำลังกันในระดับ IP (ด้วย ICMP) SYN Flood ก็นับเป็นการลองกำลังกันในระดับ TCP สิ่งที่เป็นคุณสมบัติสำคัญของ TCP คือการเชื่อมต่อที่มีเสถียรภาพ โดยมี

ขั้นตอนการสถาปนาการเชื่อมต่อ และยุติการเชื่อมต่อ แต่ข้อดีเหล่านี้ก็กลับถูกนำไปใช้เป็นอาวุธสำคัญในการโจมตี

ด้วยลักษณะในการเริ่มต้นเชื่อมต่อของ TCP นั้นจะเป็นการตรวจสอบซึ่งกันและกันทั้ง 2 ฝ่ายที่เรียกว่า 3-ways handshake โดยเริ่มต้นจากเครื่องที่ต้องการติดต่อ ส่งสัญญาณ SYN มายังเซิร์ฟเวอร์ หลังจากนั้นการเริ่มต้นการเชื่อมต่อตามโปรโตคอลก็จะดำเนินต่อไป

สิ่งที่ยากที่สุดในการทำงานของ TCP ก็คือการพยายามทำให้ทั้งสองฝ่ายสามารถสื่อสารกันได้อย่างถูกต้องและมีเสถียรภาพ สิ่งที่ต้องพิจารณาก็คือ แพ็กเก็ตของการเชื่อมต่อ จะเริ่มต้นด้วยการได้รับสัญญาณ SYN และจะต้องตอบ SYN ACK กลับไปให้แก่ผู้ที่ยิง จากนั้นต้องรอการตอบรับอีกครั้งหนึ่งของไคลเอนต์จึงจะจบกระบวนการ ดังนั้นเพื่อให้การเชื่อมต่อสามารถดำเนินไปได้อย่างต่อเนื่องโปรแกรมที่จัดการ 3-ways handshake ของเซิร์ฟเวอร์จะต้องจัดสรรหน่วยความจำจำนวนหนึ่งเพื่อรองรับการเชื่อมต่อแต่ละเซสชันจนกว่าการทำ 3-ways handshake จะสิ้นสุดลง โดยที่เซิร์ฟเวอร์เองก็ไม่มีทางรู้ได้เลยว่าไคลเอนต์จะ ACK กลับมาเพื่อจบการเชื่อมต่อหรือไม่ของ 3-ways handshake เมื่อไร ซึ่งแน่นอนว่าในการบริหารหน่วยความจำและการสื่อสารข้อมูลจะต้องสร้างความสมดุลระหว่างเสถียรภาพของเซิร์ฟเวอร์ และประสิทธิภาพของการสื่อสาร เซิร์ฟเวอร์เองก็จะมีเวลาค่าหนึ่งที่จะรอให้ได้รับสัญญาณ ACK ตอบกลับมา หากถึงเวลาที่กำหนดแล้วไม่มีแพ็กเก็ต ACK กลับมาเซิร์ฟเวอร์จะต้องยุติการรอนั้นและคืนหน่วยความจำให้แก่ระบบปฏิบัติการ

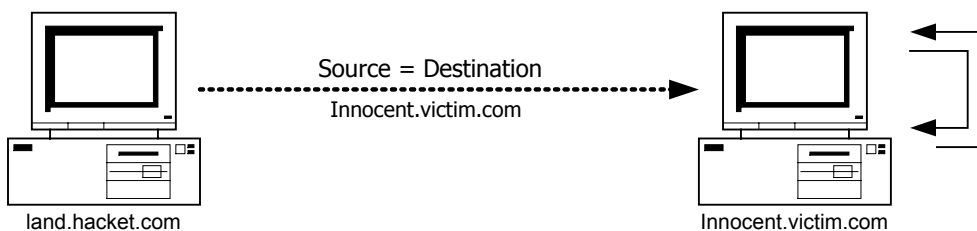
เทคนิคที่อาศัยการ SYN นี้จะส่งผลกระทบโดยตรงกับเซิร์ฟเวอร์ หากระบบปฏิบัติการของเซิร์ฟเวอร์เป้าหมายจัดการหน่วยความจำได้ไม่มีประสิทธิภาพพอก็อาจจะหยุดทำงานทันที

จนถึงปัจจุบัน SYN Flood ก็ยังเป็นการโจมตีที่ได้ผลอยู่และหาทางป้องกันได้ยาก เนื่องจากยากที่จะจำแนกลักษณะของแพ็กเก็ตที่ใช้โจมตีกับแพ็กเก็ตที่ขอเริ่มต้นการเชื่อมต่อทั่วไป โดยเฉพาะสำหรับเซิร์ฟเวอร์ที่มีอัตราสูงๆ เช่น เว็บเซิร์ฟเวอร์ และถึงแม้ว่าระบบปฏิบัติการรุ่นใหม่จะได้มีการปรับปรุงในด้านการจัดการหน่วยความจำให้ดีขึ้นแต่ก็คงจะช่วยให้เพียงเซิร์ฟเวอร์ไม่ถึงกับหยุดทำงานไปเลยเมื่อโดนโจมตีเท่านั้น แต่ก็ยากที่จะทำให้เซิร์ฟเวอร์ไม่ถึงกับหยุดทำงานไปเลยเมื่อโดนโจมตีเท่านั้น แต่ก็ยากที่จะทำให้เซิร์ฟเวอร์ยังคงรักษาความสามารถในการให้บริการได้เช่นสภาวะปกติ

Connection on innocent.victim.com		
TCP Local Address	Remote Address	State
*. *	*. *	IDLE
*.ftp	*. *	LISTEN
*.smtp	*. *	LISTEN
*.http	*. *	LISTEN
*.pop	*. *	LISTEN
innocent.http	10.15.14.1.17905	SYN_RCVD
innocent.http	10.15.14.2.17905	SYN_RCVD
innocent.http	10.15.14.3.17905	SYN_RCVD
innocent.http	10.15.14.4.17905	SYN_RCVD
innocent.http	10.15.14.5.17905	SYN_RCVD
innocent.http	10.15.14.6.17905	SYN_RCVD
innocent.http	10.15.14.7.17905	SYN_RCVD
innocent.http	10.15.14.8.17905	SYN_RCVD
*. *	*. *	IDLE

รูปที่ 5-3 แสดงสถานะการเชื่อมต่อบน innocent.victim.com เมื่อถูกโจมตี

5.3 Land Attack



CERT Advisories : Advisory CA-1997-28 IP Denial-of-Service Attacks (Topic 1)
 CVE 1999-016
 Description : Land IP Denial of Service

รูปที่ 5-4 แสดงการโจมตีแบบ Land Attack

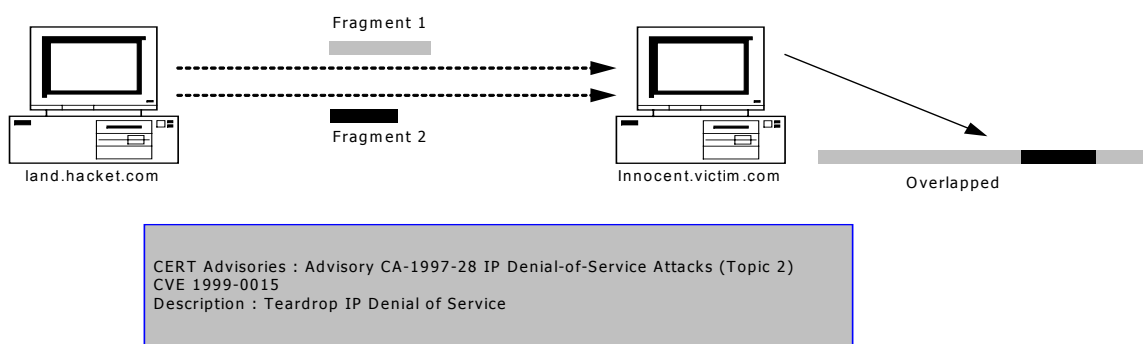
ลักษณะการโจมตี

- หมายเลข IP ต้นทางเท่ากับ IP ปลายทาง
- หมายเลขพอร์ตต้นทางเท่ากับหมายเลขพอร์ตปลายทาง
- SYN Flag ถูก Set เสมือนขอเริ่มต้นการเชื่อมต่อ
- แพ็กเก็ตจะส่งไปยัง TCP พอร์ตที่เปิดอยู่

ปกติในข้อกำหนดของ TCP เมื่อมีการส่งสัญญาณ SYN มาเพื่อการเชื่อมต่อไปยังเป้าหมาย เป้าหมายก็จะตอบรับกลับไปยังผู้ส่งด้วย SYN ACK ตามหมายเลขพอร์ตและหมายเลข IP ต้นทาง แต่สำหรับการโจมตีแบบนี้หมายเลข IP ต้นทางและปลายทางอีกทั้งหมายเลขพอร์ตต้นทางและปลายทางจะถูกตั้งให้เป็นค่าเดียวกัน

ดังนั้นการตอบกลับด้วย SYN ACK ก็จะตอบกลับไปที่ปลายทางเหมือนเดิม ซึ่งกรณีนี้ไม่มีกำหนดอยู่ในโปรโตคอลว่าควรจะทำอย่างไร โสสต์จึงพยายามตอบสนองตามข้อกำหนดเท่าที่มีอยู่โดยการตอบกลับไปที่ IP Address และพอร์ตต้นทางที่ถูกบุกรุกมานั้นหมายถึงการตอบกลับเข้ามายังตัวเอง ซึ่งจะทำให้มีการตอบกลับไปมาของ TCP วนรอบอยู่ในตัวเองด้วยความเร็วสูง ทำให้คอมพิวเตอร์ต้องใช้ทรัพยากรที่มีอยู่ทั้งหมด ไม่ว่าจะเป็น CPU หน่วยความจำและอื่นๆเพื่อคอยจัดการกับ TCP ที่ตอบกลับปามาดังกล่าวจนไม่อาจไปทำงานอื่นๆได้อีก จนดูเหมือนว่าเครื่องคอมพิวเตอร์หยุดทำงานและไม่ตอบสนองต่อการกระตุ้นใดๆแม้แต่คีย์บอร์ด ดังนั้นเหลือวิธีเดียวคือต้องรีเซ็ตเครื่องหรือปิดเครื่องจึงจะสามารถหยุดการวนรอบของ TCP ได้

5.4 Teardrop Attack



รูปที่ 5-5 แสดงการโจมตีแบบ Teardrop Attack

Teardrop เป็นการโจมตีโดยใช้ข้อบกพร่องของแฟรกเมนต์รีแอสเซมเบิล (การรวมแฟรกเมนต์แพ็กเก็ตหลายแพ็กเก็ตกลับมาเป็น IP ดาต้าแกรมเดียว) ของ IP เพื่อทำให้ระบบปฏิบัติการปลายทางของเป้าหมายทำงานผิดพลาด ไม่อยู่ในเงื่อนไขที่กำหนดไว้และหยุดทำงาน

ในการประกอบรวมแฟรกเมนต์แพ็กเก็ตกลับมาอยู่ใน 1 ดาต้าแกรมนั้น IP มีลักษณะการทำงานโดยพิจารณาจากข้อมูลของ 3 ฟิลด์คือ

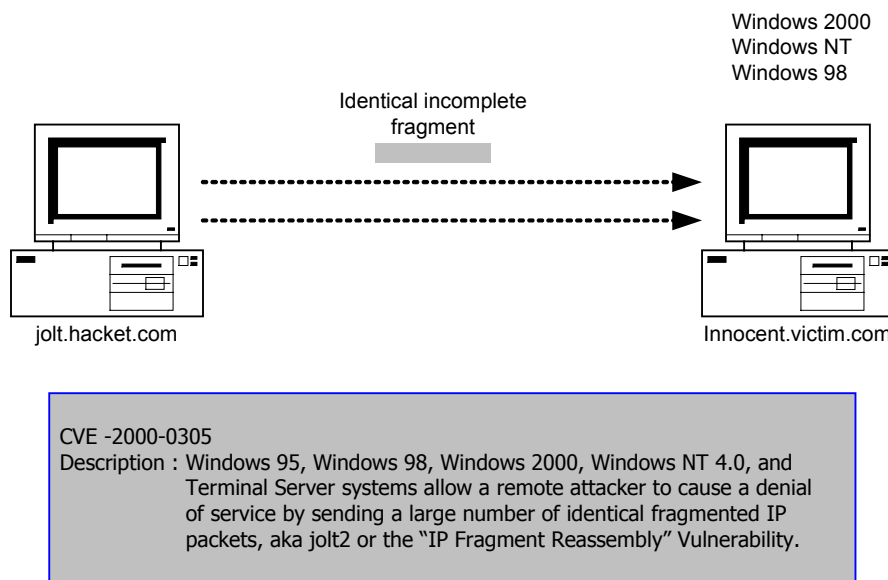
1. Data length : ขนาดความยาวของข้อมูลในแพ็กเก็ตนั้น
2. Offset : ตำแหน่งของแพ็กเก็ตที่จะนำไปประกอบรวมกลับใน IP ดาต้าแกรม
3. Flag : แฟล็กซึ่งระบุว่าไม่มีแพ็กเก็ตต่อจากแพ็กเก็ตนี้อีก หมายถึงแพ็กเก็ตนี้เป็นส่วนสุดท้ายของดาต้าแกรม

โดยทั่วไปแล้ว IP แพ็กเก็ตที่ถูกแฟรกเมนต์มานั้นไม่จำเป็นจะต้องถึงปลายทางตามลำดับ ดังนั้นปลายทางผู้รับแพ็กเก็ตจึงต้องทำการรีแอสเซมเบิลโดยนำแพ็กเก็ตที่เข้ามาไปวางรอ ไว้ตรงตำแหน่งของ offset และรอนกว่าทุกแพ็กเก็ตจะมารครบ จากนั้นจึงส่ง IP ดาต้าแกรมที่สมบูรณ์นั้นไปยังเลเยอร์ถัดขึ้นไป ด้วยลักษณะของการทำงานเช่นนี้ มีข้อบกพร่องมากมายที่สามารถนำไปใช้ในการโจมตี

หากเป็นการรับแฟรกเมนต์แฟ็กเก็ตตามปกติแล้ว IP ก็จะนำแฟรกเมนต์แต่ละแฟ็กเก็ตที่ได้รับมาวางรอไว้ในหน่วยความจำตามตำแหน่งที่ระบุในฟิลด์ offset ตามลำดับการมาถึงของแฟ็กเก็ตจะกระทั่งทุกแฟรกเมนต์ได้มาถึงครบหมดจึงรวมกลับมาเป็นดาต้าแกรมที่สมบูรณ์ หรือหากเกินเวลาที่กำหนดแล้วแฟรกเมนต์ยังเดินทางมาไม่ครบ IP ก็จะแจ้งข้อผิดพลาดกลับไปพร้อมทั้งยกเลิกการรับดาต้าแกรมนั้น

การโจมตีของ Teardrop จะใช้การหลอ่มนกันของแฟ็กเก็ตในระหว่างที่มีการรวมแฟรกเมนต์แฟ็กเก็ตเข้าด้วยกัน เนื่องจากการแฟรกเมนต์ตามปกติแล้วแฟ็กเก็ตจะถูกแบ่งออกเป็นส่วนย่อย แต่สามารถนำมารวมกันใหม่ได้พอดี และตำแหน่งจะต้องสอดคล้องกันเสมอ แฟ็กเก็ตที่ใช้ในการโจมตีของ Teardrop จะเป็นแฟ็กเก็ตที่ถูกสร้างขึ้นมาโดยเฉพาะมิได้ผ่านกลไกการแฟรกเมนต์ตามปกติของ IP โดยมีการระบุ offset ที่หลอ่มนเข้าไปในแฟ็กเก็ตอื่นๆ ซึ่งจะไม่มีโอกาสเกิดขึ้นได้เลยในการทำงานปกติ ดังนั้นหากระบบปฏิบัติการไม่สามารถจัดการเงื่อนไขไม่ปกติเช่นนี้ได้ดีเพียงพอก็จะหยุดทำงานลงได้

5.5 Jolt



รูปที่ 5-6 แสดงการโจมตีแบบ Jolt Attack

เป็นที่สังเกตได้ว่าระบบปฏิบัติการของ Microsoft จะอ่อนไหวต่อแฟรกเมนต์แฟ็กเก็ตเป็นพิเศษ การ DoS สำหรับ Windows ส่วนใหญ่สามารถกระทำได้ง่าย โดยอาศัย Fragment และ ส่งผลเสียต่อเป้าหมายได้ค่อนข้างมาก

ส่วนใหญ่เมื่อเซิร์ฟเวอร์ถูกโจมตีด้วย Fragment แล้วจะปรากฏอาการคือ

- หยุดการทำงานและแสดงหน้าจอสีฟ้า (Blue Screen) ต้องทำการ Cold boot เครื่องใหม่ หรืออาจจะต้องปิดเครื่องแล้วเปิดใหม่

- หยุดการทำงานเครื่องชั่วขณะ เซิร์ฟเวอร์ไม่ตอบสนองใดๆเหมือนกับแสงค์ ผู้ใช้จะไม่สามารถควบคุมหรือติดต่อกับระบบปฏิบัติการได้ ส่วนใหญ่ผู้ใช้ก็ต้อง Reset และปิดเครื่องแล้วเปิดใหม่เช่นเดียวกัน

- ทำงานช้าลงไปมาก ตอบสนองต่อผู้ใช้อย่างช้ามาก เนื่องจาก CPU จะถูกนำไปใช้ในการจัดการกับ Fragment ที่เข้ามา หากโดนโจมตีมากๆเครื่องก็จะไม่ตอบสนองอีกเลย

Jolt เป็นการโจมตีโดยอาศัยแฟรกเมนต์ทั่วไป แสกเกอร์จะอาศัยการส่งแฟรกเมนต์แฟ็กเก็ตซ้ำๆจำนวนมากอย่างต่อเนื่องมายังเซิร์ฟเวอร์เป้าหมาย หากข้อมูลมีความเร็วและปริมาณไม่มากพอก็จะเพียงแต่ทำงานช้าลงกว่าปกติ หากแสกเกอร์สามารถเพิ่มความเร็วในการส่งข้อมูลเครื่องก็จะหยุดทำงานไม่ตอบสนองต่อผู้ใช้อีกเลย CPU Utilization จะขึ้นสูงถึง 100% และถูกใช้ไปโดยเคอร์เนล (Kernel) ของระบบปฏิบัติการ นั่นเป็นเหตุผลที่ทำให้ไม่มีการตอบสนองใดๆต่อผู้ใช้ เนื่องจากกำลังของ CPU ถูกใช้ไปในการจัดการกับ Fragment หมดนั่นเอง